

Preliminary Experiment Results

Data Poisoning and Prompt Injection Attacks on Retrieval-Augmented Generation (RAG) Systems

Course:	CSE 4531 (C): Computer Security	University:	United International University
Group & Sec:	Group ID: 06 (Section C)	Semester & Date:	Summer 2026 21 July 2026
Team Members:	011222245 - Jakaria Molla 011222177 - Easmin Akter Tule 011222172 - Taki Tahmid 011222285 - Pranto Shahriar Bishal		

1. Purpose & Scope

This report documents the preliminary laboratory experiment conducted following our literature review for CSE 4531. The objective is to evaluate how injecting an untrusted or outdated document into a Retrieval-Augmented Generation (RAG) knowledge base affects vector document retrieval and the final synthesized response generated by Google Gemini. This is an initial experimental validation of RAG document trust risks, serving as the 21 July course milestone.

2. Technical Setup

Component	Specification	Component	Specification
Programming Language	Python 3.11+	Vector Database	ChromaDB
Orchestration Framework	LangChain	Embedding Model	Sentence Transformers (BAAI/bge-m3)
Language Model (LLM)	Google Gemini API (1.5 Flash)	Document Loader	PyPDF Loader
Trusted Policy Corpus	5 PDF Documents	Inconsistent Document	1 Outdated PDF Manual

3. Experiment Design

Phase 1 (Trusted Knowledge Base): ChromaDB was populated with 5 official policies: *Password Policy*, *VPN Policy*, *MFA Standard*, *Leave Policy*, and *Security Guidelines*. Two baseline test queries were executed to record retrieval ranking and Gemini answers.

Phase 2 (Mixed Knowledge Base): One inconsistent document (*outdated_vpn_policy.pdf*) containing conflicting guidance (plain-text password email reset, unencrypted setup ZIP download without MFA) was added. The exact same queries were re-evaluated to observe retrieval drift and context window contamination.

4. Architectural Workflow Diagrams

Figure 1: Baseline RAG Workflow (Phase 1: Trusted Corpus)



Figure 1: Standard retrieval pipeline producing verified responses.

Figure 2: Mixed Knowledge Base Workflow (Phase 2: Inconsistent Document Ingestion)

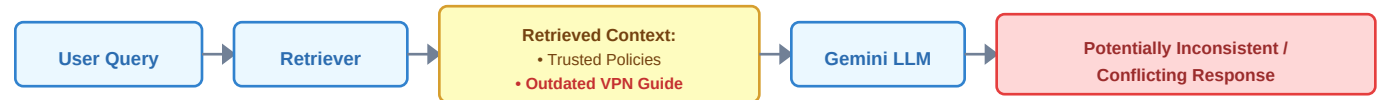


Figure 2: Vector context window contamination resulting from unfiltered similarity search.

5. Experimental Results & Observations

Query	Retrieved Context (Phase 1: Trusted)	Retrieved Context (Phase 2: Mixed)	Retrieval & LLM Impact Observation
Q1: Password Reset Procedure	1. password_policy.pdf 2. security_guidelines.pdf 3. mfa_policy.pdf	1. password_policy.pdf 2. outdated_vpn_policy.pdf 3. security_guidelines.pdf	Outdated policy appeared in Top-3 results (\$L_2\$ distance 1.2883), introducing plain-text email reset instructions into Gemini's context window.
Q2: VPN Access Configuration	1. vpn_policy.pdf 2. leave_policy.pdf 3. password_policy.pdf	1. vpn_policy.pdf 2. outdated_vpn_policy.pdf 3. leave_policy.pdf	Legacy guide ranked 2nd (\$L_2\$ distance 1.3300), supplying an unencrypted ZIP setup link and stating MFA is not required.

Impact Analysis on Gemini Output

The Gemini responses remained mostly correct because official documents maintained top similarity scores. However, because the retrieved context now contained conflicting legacy directives, Gemini included these inconsistent statements in its synthesized output. This demonstrates that LLMs receive conflicting evidence if no document trust mechanism is applied.

6. Discussion & Research Gap

Discussion: The retrieval stage is the first point where knowledge quality directly affects the generated response. Recent studies such as PoisonedRAG and CorruptRAG demonstrate that malicious documents can successfully manipulate RAG outputs. Existing defenses mainly rely on document validation, keyword matching, metadata verification, and trust-based retrieval filtering. While these reduce direct attack success, key challenges remain unresolved.

Research Gap: First, most systems focus on explicit prompt injection and struggle to identify obfuscated instructions (e.g., sentence initials, Unicode characters, invisible text, indirect language). Second, current defenses primarily evaluate English documents, with limited work in multilingual environments, especially low-resource languages like Bangla. Third, many defenses require expensive LLM-based verification for every retrieved document, increasing latency and cost. Therefore, this project proposes to investigate a lightweight document sanitization framework capable of detecting malicious documents before indexing into the vector database while supporting multilingual content.

7. Proposed Future Defense & Conclusion

Figure 3: Proposed Pre-Indexing Trust Evaluation & Sanitization Framework

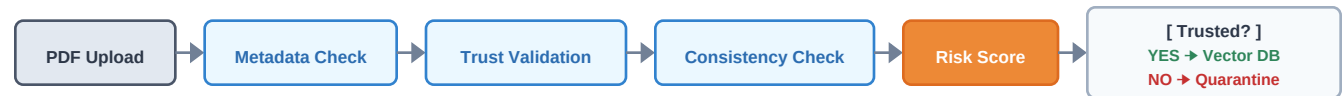


Figure 3: Defensive pipeline validating document metadata, trust, and consistency prior to vector storage.

Conclusion: Using BAAI/bge-m3, the mixed corpus contaminated Top-3 retrieval for both test questions, while the implemented pre-index gate quarantined the untrusted document and reduced observed contamination to zero on this preliminary two-question benchmark. Larger adversarial and multilingual evaluations remain necessary.

Appendix: Source Code Repository: All experimental code and log data are available at: <https://github.com/takitahmid20/rag-data-poisoning>